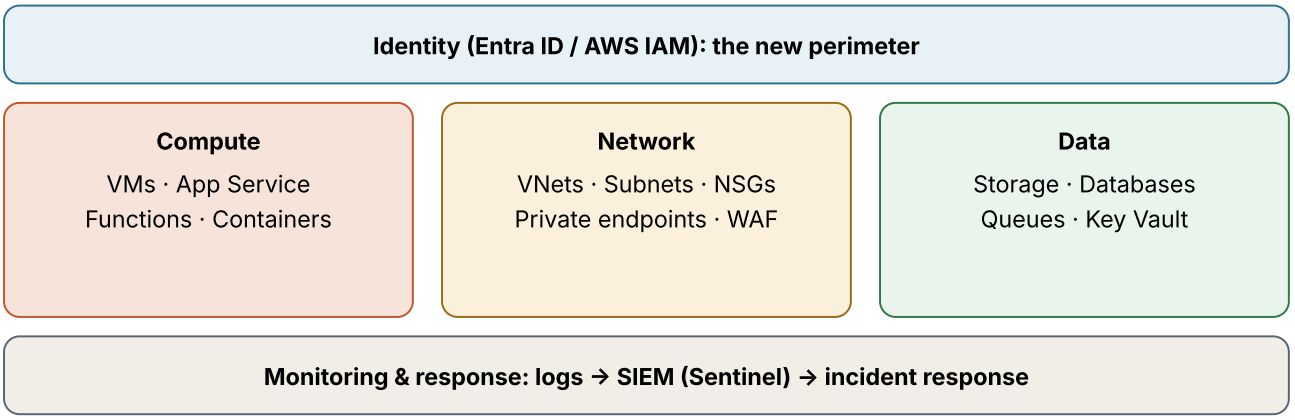
CLOUD SECURITY PATH · STUDY GUIDE 3

# Cloud & Cloud Security Foundations

Everything a Cloud Security Engineer builds on: cloud models, compute, storage, networks, databases and queues, identity, data protection, secure design, monitoring and incident response. Azure first, with every AWS equivalent mapped. Part C covers securing small organisations end to end.




## Contents


A *Cloud foundations*
1 What cloud computing is
2 Service models: IaaS, PaaS, SaaS
3 Deployment models
4 Shared responsibility
5 Global infrastructure and accounts
6 Compute
7 Storage
8 Networking: VNets and VPCs
9 Databases and queues
B *Cloud security*
10 Identity and access management
11 Data security
12 Securing cloud infrastructure
13 Monitoring and logging
14 Cloud incident response
C *Securing small organisations*
15 The essential controls
16 Email and Microsoft 365 security
17 Vulnerability management, patching, backups
18 Running security monitoring as a service
19 Frameworks and compliance
20 Glossary and answers

# 1 What cloud computing is

> **Cloud computing is renting computing resources (servers, storage, networks, software) over the internet, on demand, paying only for what you use.**

The standard definition (NIST SP 800-145) lists five essential characteristics:

| Characteristic | Meaning | Example |
|---|---|---|
| **On-demand self-service** | Create resources yourself, instantly, without calling anyone | Click "Create VM" in the Azure portal |
| **Broad network access** | Reach services over the network from any device | Manage Azure from a laptop or phone |
| **Resource pooling** | Many customers share the provider's hardware, isolated from each other | Your VM shares a physical host with strangers' VMs |
| **Rapid elasticity** | Scale up or down quickly, even automatically | Add 10 web servers during a sale, remove them after |
| **Measured service** | Usage is metered and billed | Pay per second of VM time and per GB stored |

**THINK OF IT LIKE THIS**

Owning servers is like owning a generator: you buy it, fuel it and fix it. Cloud is like the electricity grid: plug in, use what you need, pay the bill. The catch is that you're still responsible for what you plug in and who you let use the sockets.

**IN YOUR LAB**

Your home lab is a small private "cloud" on one laptop: resource pooling (four VMs sharing hardware), but no self-service portal, elasticity or billing.

**QUICK CHECK (answers at the back)**

1. Name the five essential characteristics of cloud computing.
2. Which characteristic means many customers share the same hardware?

# 2 Service models: IaaS, PaaS, SaaS

> **The service model decides how much the provider manages and how much you manage. The more the provider manages, the less you control, and the less you must secure yourself.**

| Model | You get | You manage | Azure | AWS |
|---|---|---|---|---|
| **IaaS**: Infrastructure as a Service | Raw VMs, disks, networks | OS, patching, apps, data, access | Virtual Machines | EC2 |
| **PaaS**: Platform as a Service | A ready platform to run your code or database | Your code, data, access, configuration | App Service, Azure SQL | Elastic Beanstalk, RDS |
| **SaaS**: Software as a Service | A finished application | Your data, users and settings | Microsoft 365 | (third-party SaaS on AWS) |
| **FaaS** / serverless | Run individual functions on events | Function code and permissions | Azure Functions | Lambda |
| **BaaS**: Backend as a Service | Ready-made app backends: login, database, file storage | App logic, data rules | (Azure Mobile/App Service features) | Amplify |

**THINK OF IT LIKE THIS**

**Pizza as a service.** IaaS: you're given a kitchen and you cook. PaaS: the pizza is baked for you; you choose the toppings. SaaS: the pizza is delivered and you just eat. In every case, *you* decide who gets a slice, which is identity and data.

**REMEMBER**

Whatever the model, **you always own your data, your identities and your access settings**. Most real cloud breaches happen in that customer-owned layer.

**QUICK CHECK (answers at the back)**

3. In IaaS, who patches the operating system?
4. Give one Azure and one AWS example of PaaS.
5. What do you still own even in SaaS?

# 3 Deployment models

> **The deployment model says who owns the infrastructure and who can use it.**

| Model | What it is | Pros | Cons | Example |
|---|---|---|---|---|
| **Public** | Provider-owned, shared by many customers | No hardware to buy; global scale; pay as you go | Less control; shared tenancy; costs can surprise you | Azure, AWS, Google Cloud |
| **Private** | Dedicated to one organisation, on-prem or hosted | Full control; data stays in-house | Expensive; you run it all | A bank's VMware or OpenStack data centre; your home lab |
| **Hybrid** | Private and public connected and used together | Keep sensitive systems in-house, burst to the cloud | Complex networking and identity | On-prem AD synced to Entra ID; **your lab v2** |
| **Community** | Shared by organisations with common needs | Shared cost; common compliance | Shared governance | Government clouds, healthcare consortia |
| **Multi-cloud** | Using more than one public cloud | Avoids lock-in; best service from each | Several security models to learn | Azure for identity, AWS for apps |

**IN YOUR LAB**

Lab v2 is **hybrid**: your on-prem lab (private) connected to Azure (public) through Azure Arc, monitored by one SIEM. That's what most companies really run.

**QUICK CHECK (answers at the back)**

6. What makes a cloud "hybrid"?
7. Give one reason a bank might keep a private cloud.

# 4 The shared responsibility model

> **Security *of* the cloud is the provider's job. Security *in* the cloud is your job. Where the line falls depends on the service model.**

| IaaS | PaaS | SaaS |
|---|---|---|
| Data & access | Data & access | Data & access |
| Applications | Applications | Applications |
| Operating system | Operating system | Operating system |
| Network controls (NSGs) | Network controls (shared) | Network controls |
| Virtualization | Virtualization | Virtualization |
| Physical hosts & network | Physical hosts & network | Physical hosts & network |
| Data centre | Data centre | Data centre |

You (customer) · Provider · Shared

**Always yours, in every model:** your data, your identities and accounts, who has access, and how you configure what you're given.

**REMEMBER**

Most cloud breaches aren't the provider being hacked. They're customer-side mistakes: **public storage, leaked keys, over-permissive access, missing MFA**. A Cloud Security Engineer's job is mostly preventing and catching those.

**QUICK CHECK (answers at the back)**

8. In PaaS, who patches the operating system?
9. Name two security responsibilities that stay with the customer in every model.

# 5 Global infrastructure and accounts

> **Clouds are made of regions (geographic areas), each with several availability zones (separate data centres). Your resources live inside an account structure that also defines security boundaries.**

| Concept | Azure | AWS | Why it matters |
|---|---|---|---|
| Geographic area | Region (e.g. South Africa North, UK South) | Region (e.g. af-south-1, eu-west-2) | Latency, cost and **data residency law** |
| Separate data centres | Availability zones | Availability zones | Survive a data-centre failure |
| Top of the hierarchy | Entra tenant → management groups | AWS Organizations → organizational units | Apply policies to many accounts at once |
| Billing and security boundary | Subscription | Account | Separate dev, prod and lab environments |
| Grouping of resources | Resource group | (tags, CloudFormation stacks) | Manage and delete things together |
| The all-powerful identity | Global Administrator; subscription Owner | **Root user** | Protect with MFA; never use day to day |

### First things to do in any new cloud account

1. **MFA** on the top account (Azure Global Admin; AWS root user).
2. Create a separate admin user for daily work. Lock the top account away and keep a "break-glass" emergency account.
3. Set a **budget with alerts** before you build anything.
4. Turn on the activity logs (on by default in Azure; in AWS, create a CloudTrail trail that keeps logs long-term).
5. Decide naming and **tags** (owner, environment, cost centre).

**QUICK CHECK (answers at the back)**

10. What is the AWS equivalent of an Azure subscription?
11. What two things should you set up before building anything in a new cloud account?

# 6 Compute

> **Compute is where code runs: full VMs you manage yourself, managed app platforms, serverless functions or containers.**

| Type | Azure | AWS | You secure |
|---|---|---|---|
| Virtual machines (IaaS) | Azure Virtual Machines, scale sets | EC2, Auto Scaling groups | OS hardening, patching, NSG/SG rules, disk encryption, access (no public SSH/RDP) |
| Managed web apps (PaaS) | **App Service** | **Elastic Beanstalk** | App code, HTTPS-only, authentication, secrets, network restrictions |
| Serverless functions | Azure Functions | Lambda | Function permissions (least privilege), input validation, secrets |
| Containers | Container Instances, Container Apps, AKS | ECS, Fargate, EKS | Image security, registry access, runtime privileges (Guide 2) |

## VM security checklist

- **No public IP**, or none with SSH/RDP open to the internet. Use Azure Bastion or AWS Session Manager.
- **SSH keys**, not passwords (as on your Ubuntu server). Microsoft Entra login for Windows and Linux VMs where possible.
- **Patch automatically** (Azure Update Manager; AWS Systems Manager Patch Manager).
- **Managed identity / IAM role** for the VM, never access keys stored on the disk.
- **Encrypt disks** (on by default; customer-managed keys for stricter control).
- **Endpoint protection** (Defender for Servers; or the Wazuh agent you already know).

## App Service vs Elastic Beanstalk

Both let you deploy a web app without managing servers. **App Service** is fully managed PaaS: you upload code and Azure runs it. **Elastic Beanstalk** is an orchestration layer: it creates and manages EC2, load balancers and scaling *for* you, and you can still see and change those resources.

**QUICK CHECK (answers at the back)**

12. Why should a VM use a managed identity or IAM role instead of an access key?
13. How do you reach a VM securely with no public IP?

# 7 Storage

> **Cloud object storage holds files ("objects" or "blobs") at huge scale. It's one of the most useful cloud services, and historically one of the most common sources of data leaks.**

| | Azure | AWS |
|---|---|---|
| Object storage | **Storage account → containers → blobs** | **S3 buckets → objects** |
| File shares | Azure Files | EFS, FSx |
| VM disks | Managed disks | EBS volumes |
| Cost tiers | Hot, Cool, Cold, Archive | Standard, Infrequent Access, Glacier classes |
| Block public access | Disable "allow blob public access" | **S3 Block Public Access** |
| Temporary access link | **SAS** (shared access signature) | **Pre-signed URL** |
| Ransomware protection | Soft delete, versioning, immutable storage | Versioning, **Object Lock** |
| Private network access | Private endpoint | VPC endpoint (gateway / interface) |

## Storage security essentials

- **Never public by default.** Keep public access blocked at the account level, and allow exceptions only deliberately.
- **Prefer identity-based access** (Entra ID / IAM roles) over shared keys. Azure storage **account keys** give full access, so treat them like root passwords and rotate them.
- **Short-lived SAS / pre-signed URLs**: minimal permissions and a short expiry. A long-lived SAS link is a leaked password waiting to happen.
- **Encryption at rest** is on by default in both clouds. Use customer-managed keys when policy requires it (chapter 11).
- **Enforce HTTPS / TLS** for all access.
- **Turn on logging** (Azure storage diagnostic logs; S3 server access logs or CloudTrail data events) to see who read what.
- **Versioning plus immutability**, so ransomware or a malicious admin can't silently destroy data.

**QUICK CHECK (answers at the back)**

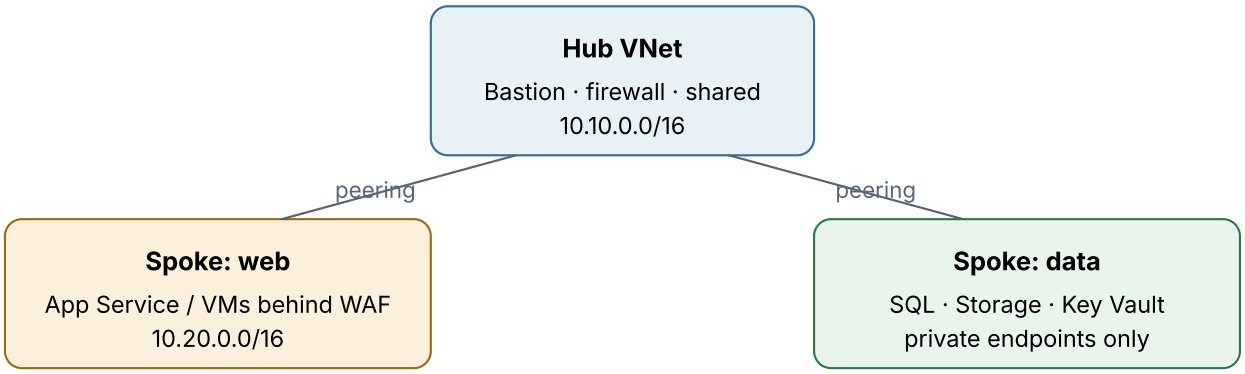
14. What is the Azure equivalent of an S3 bucket?
15. Why are long-lived SAS links risky?
16. Name two controls that protect stored data from ransomware.

# 8 Networking: VNets and VPCs

> **A VNet (Azure) or VPC (AWS) is your private network in the cloud, split into subnets and controlled by route tables and network security rules. It's your pfSense lab, rebuilt in software.**

| Concept | Azure | AWS | Your lab |
|---|---|---|---|
| Private network | VNet | VPC | The whole lab |
| Segment | Subnet | Subnet (in one AZ) | LAN / DMZ / MGMT |
| Routing | Route tables (system routes plus user-defined routes) | Route tables | pfSense routing |
| Internet in | Public IP / load balancer | Internet gateway + public IP | None (by design) |
| Internet out only | NAT gateway | NAT gateway | pfSense outbound NAT |
| Stateful filtering | **NSG** (subnet or NIC), plus application security groups | **Security group** (instance/ENI, allow rules only) | pfSense rules |
| Stateless filtering | (none) | **Network ACL** (subnet level, allow and deny) | |
| Connect networks | VNet peering, VPN gateway, ExpressRoute | VPC peering, Transit Gateway, VPN, Direct Connect | |
| Private access to PaaS | Private endpoint (Private Link) | VPC interface endpoint (PrivateLink) | |
| Admin access | Azure Bastion | Session Manager | SSH from Kali |
| Central firewall / WAF | Azure Firewall; App Gateway WAF | AWS Network Firewall; AWS WAF | pfSense |
| Traffic logs | VNet / NSG flow logs | VPC Flow Logs | pfSense firewall logs |

## A secure design: hub and spoke




- Shared security services (Bastion, firewall) live in the **hub**. Workloads live in **spokes**, peered to the hub.
- The data spoke has **no internet path**. Databases and storage are reached only through **private endpoints**.
- NSGs on every subnet, with **default deny** and only the flows each tier needs, exactly like your pfSense zones.

**REMEMBER**

Two cloud-specific traps. **(1)** Subnets in the same VNet/VPC can reach each other **by default**, so segmentation must be added with NSGs or security groups. **(2)** A "private" PaaS service may still have a **public endpoint** unless you disable it.

**QUICK CHECK (answers at the back)**

17. Security group vs network ACL: which is stateful?
18. What is a private endpoint for?
19. Why put Bastion and the firewall in a hub VNet?

# 9 Databases and queues

> **Managed databases and messaging services are PaaS: the provider runs the servers, and you secure access, network exposure, encryption and auditing.**

## Databases

| Type | Azure | AWS |
|---|---|---|
| Relational (SQL) | Azure SQL Database, Azure Database for PostgreSQL / MySQL | RDS (PostgreSQL, MySQL, SQL Server...), Aurora |
| NoSQL | Cosmos DB | DynamoDB |
| Cache | Azure Cache for Redis | ElastiCache |

**Secure a database by:** disabling public network access (use private endpoints); using Entra ID / IAM authentication instead of shared passwords; encryption at rest (TDE, on by default) and TLS in transit; automated backups with tested restores; auditing and threat detection (Defender for SQL; RDS logs to CloudWatch); least-privilege database users for applications.

## Queues and messaging

Queues let parts of an application hand work to each other without waiting: an order is placed in a queue, and a worker processes it later. This makes apps resilient and scalable.

| Purpose | Azure | AWS |
|---|---|---|
| Simple queue | **Queue Storage** | **SQS** |
| Enterprise messaging (queues and topics) | Service Bus | SQS + **SNS**, Amazon MQ |
| Events | Event Grid, Event Hubs | EventBridge, Kinesis |

**Secure queues by:** using managed identities / IAM roles for producers and consumers; private endpoints; encryption; dead-letter queues for poisoned messages; and treating message content as **untrusted input** that gets validated before use.

**QUICK CHECK (answers at the back)**

20. What is the AWS equivalent of Azure Queue Storage?
21. Give three controls for securing a managed database.

# 10 Identity and access management

> **In the cloud, identity is the perimeter. Anyone with valid credentials and permissions can reach your resources from anywhere, so IAM is the most important cloud security skill.**

## The building blocks

| Concept | Azure / Entra ID | AWS |
|---|---|---|
| Directory of identities | **Microsoft Entra ID** (users, groups) | IAM users and groups; IAM Identity Center for SSO |
| Identity for apps | Service principal; **managed identity** | **IAM role** (temporary credentials via STS) |
| Permissions | **Azure RBAC**: role + identity + scope | **IAM policies** (JSON) attached to identities or resources |
| Top-level guardrails | Azure Policy; management groups | Service control policies (SCPs) |
| Risk-based sign-in rules | **Conditional Access** (Entra ID P1); security defaults (free) | IAM conditions; IAM Identity Center MFA |
| Just-in-time admin | **Privileged Identity Management (PIM)** (P2) | Temporary role assumption, time-bound access |

## Azure RBAC: who, what, where

A **role assignment** = a **security principal** (who) + a **role definition** (what: e.g. Owner, Contributor, Reader) + a **scope** (where: management group → subscription → resource group → resource). Permissions inherit downwards. Note that **Entra roles** (like Global Administrator, which manage the directory) are separate from **Azure RBAC roles** (which manage resources).

## An AWS IAM policy

```
{
  "Version": "2012-10-17",
  "Statement": [{
    "Effect": "Allow",
    "Action": ["s3:GetObject"],
    "Resource": "arn:aws:s3:::lab-reports/*"
  }]
}
```

This allows **only** reading objects in one bucket. Anything not allowed is **implicitly denied**, and an explicit `"Deny"` always wins. That's the same default-deny logic as your pfSense rules.

## IAM best practices

- **MFA everywhere**, phishing-resistant (FIDO2 keys, passkeys) for admins.
- **Least privilege:** start with nothing, add only what's needed; prefer narrow scopes and Reader over Contributor.

- **No long-lived keys:** use managed identities and roles. Never put access keys in code or Git.
- **Separate admin accounts** and just-in-time elevation (PIM).
- **Block legacy authentication** (protocols that can't do MFA).
- **Review access regularly;** remove leavers and unused permissions.
- **Break-glass accounts:** two emergency admin accounts, excluded from normal policies, strongly protected and monitored.

**REMEMBER**

The most common cloud attack chain: **phished or leaked credential → no MFA → over-privileged account → data stolen or crypto-miners deployed**. Every IAM control breaks one link.

**QUICK CHECK (answers at the back)**

22. What three parts make an Azure role assignment?
23. In AWS IAM, what happens to an action that no policy allows?
24. Why prefer a managed identity over an access key?

# 11 Data security

> **Data must be protected in all three states: at rest (stored), in transit (moving) and in use (being processed).**

| State | Threat | Controls | Azure | AWS |
|---|---|---|---|---|
| **At rest** | Stolen disks, snapshots or backups; storage misconfiguration | Encryption, access control, immutability | Storage Service Encryption, Azure Disk Encryption, SQL TDE, **Key Vault** | S3/EBS/RDS encryption, **KMS** |
| **In transit** | Eavesdropping, man-in-the-middle | TLS 1.2+, HTTPS-only, private connections, VPN | HTTPS-only settings, minimum TLS version, Private Link | ACM certificates, bucket policies requiring TLS, PrivateLink |
| **In use** | Memory scraping, a malicious admin on the host | Confidential computing (hardware-isolated enclaves) | Confidential VMs and containers | Nitro Enclaves |

## Key management

- **Platform-managed keys** (the default): the provider creates and rotates keys. Easy, and fine for most data.
- **Customer-managed keys (CMK)** in Key Vault or KMS: you control rotation and can revoke access. Needed for some compliance rules.
- Separate who can **use** keys from who can **manage** them (separation of duties); log every key operation; enable soft delete and purge protection so keys can't be destroyed by mistake or by an attacker.
- **Secrets** (passwords, API keys, connection strings) go in Key Vault or AWS Secrets Manager, never in code or config files.

## Knowing what you're protecting

- **Data classification:** label data as public, internal, confidential or restricted, then apply controls by label (Microsoft Purview; Amazon Macie finds sensitive data in S3).
- **Data loss prevention (DLP):** block sensitive data leaving by email, sharing or USB.
- **Backups:** encrypted, immutable and tested (Guide 2, chapter 6).
- **Data residency:** privacy laws may require personal data to stay in certain countries. Choose regions accordingly.

QUICK CHECK (answers at the back)

25. Name the three states of data and one control for each.
26. What is a customer-managed key, and why use one?
27. Where should application secrets be stored?

# 12 Securing cloud infrastructure

> **Secure cloud infrastructure is designed in, defined as code, enforced by policy and checked continuously, not configured by hand and hoped for.**

## The building blocks

| Practice | What it means | Azure | AWS |
|---|---|---|---|
| **Landing zone** | A pre-built, secure foundation: account structure, networks, identity, logging, policies | Azure Landing Zones | Control Tower |
| **Infrastructure as Code (IaC)** | Define resources in code files, review them like software, and deploy them repeatably | Terraform, Bicep | Terraform, CloudFormation |
| **Policy as code** | Rules that block or flag insecure settings automatically | Azure Policy | AWS Config rules, SCPs |
| **Posture management (CSPM)** | Continuously scan for misconfigurations and score your security | Defender for Cloud (secure score) | Security Hub |
| **Workload protection (CWPP)** | Threat protection for VMs, containers, databases | Defender for Cloud plans | GuardDuty, Inspector |
| **Benchmarks** | Agreed secure baselines to measure against | Microsoft cloud security benchmark, CIS | AWS Foundational Security Best Practices, CIS |

## The misconfigurations behind most cloud incidents

1. Public storage buckets or containers.
2. SSH/RDP (22/3389) open to the internet (`0.0.0.0/0`).
3. Admin accounts without MFA; the root account used day to day.
4. Access keys in code, Git repos or VM disks.
5. Over-permissive roles (Owner or `*:*` everywhere).
6. Databases with public endpoints.
7. Logging turned off or not retained.
8. Unencrypted or publicly shared snapshots.

## Why IaC is a security control

With Terraform, your whole environment is a reviewable file. You can **scan it before deployment** (tools such as Checkov or tfsec flag insecure settings), keep it in Git (who changed what, and when), rebuild it identically after an incident, and **destroy it at the end of every lab session** to avoid costs.

**IN YOUR LAB**

Phase 8 builds the hub-and-spoke network in Azure with Terraform. Phase 12 scans AWS with **Prowler**, an open-source posture scanner, and fixes the findings.

**QUICK CHECK (answers at the back)**

28. What does a CSPM tool do?
29. Name four common cloud misconfigurations.
30. Give two ways IaC improves security.

# 13 Monitoring and logging

> **You can't detect what you don't log. Cloud logs fall into three groups: control-plane activity (who changed what), sign-ins, and data or network activity. A SIEM brings them together.**

| What you need to know | Azure | AWS |
|---|---|---|
| **Who did what to my resources?** (control plane) | **Activity Log** | **CloudTrail** (management events) |
| Who signed in, from where, and did it succeed? | Entra ID **sign-in** and **audit** logs | CloudTrail (console logins), IAM Identity Center logs |
| Who read or wrote my data? | Resource / diagnostic logs (storage, SQL, Key Vault) | CloudTrail data events, S3 access logs |
| What network traffic flowed? | VNet / NSG flow logs | **VPC Flow Logs** |
| Metrics, log storage, alerts | Azure Monitor, **Log Analytics workspace** | **CloudWatch** (metrics, Logs, alarms) |
| Automatic threat detection | **Defender for Cloud** | **GuardDuty** (analyses CloudTrail, VPC flow and DNS logs) |
| Configuration history and compliance | Azure Policy, Resource Graph | AWS Config |
| Central findings dashboard | Defender for Cloud | Security Hub |
| **SIEM + SOAR** | **Microsoft Sentinel** | (Security Lake + partner SIEMs, or Sentinel connectors) |

## KQL: the language of Sentinel and Log Analytics

This query looks for many failed sign-ins per user and IP in 5-minute windows. It's the cloud version of your Wazuh rule 100100:

```
SigninLogs
| where ResultType != "0"            // "0" means success
| summarize Failures = count() by UserPrincipalName, IPAddress, bin(TimeGenerated, 5m)
| where Failures > 10
| order by Failures desc
```

Read it top to bottom: take the sign-in logs → keep failures → count them per user, IP and 5-minute window → keep only the noisy ones → sort.

## Logging essentials

- Turn on logs **before** you need them, because you can't go back in time.
- Send logs to a **central workspace** in a separate, locked-down subscription or account, so an attacker who compromises a workload can't delete the evidence.
- Set **retention** to match policy and law.

- Keep clocks consistent. The cloud does this for you, but hybrid sources need NTP (your Case 001).
- Tune alerts and remove duplicates, as you did in your lab.

**QUICK CHECK (answers at the back)**

31. Which service answers "who changed my resources?" in Azure, and which in AWS?
32. What does GuardDuty analyse?
33. Why store logs in a separate, locked-down subscription or account?

# 14 Cloud incident response

> **Incident response in the cloud follows the same lifecycle as on-prem, but evidence lives in logs and APIs, attackers move through identities, and containment is often a configuration change.**

## The lifecycle (NIST SP 800-61)

1. **Preparation:** logging on, a SIEM, playbooks, break-glass accounts, contacts, and practice.
2. **Detection and analysis:** triage the alert, scope it, build a timeline from logs.
3. **Containment, eradication and recovery:** stop the spread, remove the attacker, restore safely.
4. **Post-incident activity:** lessons learned, fix the root cause, update detections.

## Four common cloud incidents

| Scenario | Contain | Investigate | Recover and prevent |
|---|---|---|---|
| **Leaked access key** (e.g. pushed to GitHub) | Deactivate the key immediately; create a replacement | CloudTrail / Activity Log for everything the key did: new users, new keys, new resources, data access | Remove anything the attacker created; secret scanning on repos; use roles instead of keys |
| **Compromised user account** | Disable the account or reset its password; **revoke sessions and tokens**; re-register MFA | Sign-in logs (locations, IPs), audit logs, mailbox rules and forwarding, app consents | Enforce MFA and Conditional Access; block legacy authentication |
| **Public storage exposure** | Block public access | Access logs: was data actually downloaded, by whom? | Account-level public-access block; policy to deny public storage; legal notification if personal data was exposed |
| **Compromised VM** (e.g. a crypto-miner) | **Isolate** with a quarantine NSG / security group; **don't delete it yet** | **Snapshot the disk** for evidence; review flow logs, process lists, and the identity the VM used | Rebuild from a clean image; rotate any credentials the VM could reach; patch the entry point |

## Automation (SOAR)

**Sentinel playbooks** (built on Logic Apps) and **AWS EventBridge + Lambda** can respond in seconds: disable a user, block an IP, isolate a VM, or open a ticket and notify the analyst. Automate the repetitive, well-understood steps, and keep a human in the loop for decisions that are destructive or ambiguous.

**REMEMBER**

In the cloud, **preserve before you destroy**. Snapshot disks and export logs before deleting anything. A deleted VM takes its evidence with it.

**QUICK CHECK (answers at the back)**

34. What are the four phases of the NIST incident response lifecycle?
35. A developer leaked an access key on GitHub. What is your first action?
36. Why snapshot a compromised VM before deleting it?

# 15 Securing small organisations: the essential controls

> **Most small businesses don't need complex tools. A short list of basics, done consistently, stops the majority of real attacks: phishing, account takeover, unpatched systems and ransomware.**

These follow the spirit of the **CIS Critical Security Controls, Implementation Group 1** ("essential cyber hygiene") and similar national baselines.

| # | Control | What "good" looks like | Tools |
|---|---|---|---|
| 1 | **Know your assets** | A list of every laptop, phone, server, account and cloud service | Wazuh inventory (syscollector), Intune, RMM tools |
| 2 | **MFA everywhere** | Email, admin accounts, remote access and finance systems all need MFA | Entra ID security defaults or Conditional Access |
| 3 | **Patch promptly** | OS and apps updated automatically; critical fixes within days | Windows Update / Intune, Wazuh vulnerability detection |
| 4 | **Endpoint protection** | Antivirus/EDR on every device, monitored | Microsoft Defender, other EDR products, the Wazuh agent |
| 5 | **Email security** | Spam and phishing filtering; SPF, DKIM and DMARC set up | Microsoft 365 / Google Workspace protections (chapter 16) |
| 6 | **Backups** | 3-2-1, one copy immutable or offline, restores tested | Azure Backup, M365 backup tools, external drives |
| 7 | **Least privilege** | Staff don't use admin accounts day to day; leavers removed promptly | Entra ID, local admin removal |
| 8 | **Security awareness** | Short, regular phishing and scam training; a way to report suspicious messages | Simulated phishing tools, short briefings |
| 9 | **Logging and monitoring** | Key logs collected and someone actually reviews alerts | Wazuh, Sentinel |
| 10 | **Incident response plan** | A one-page plan: who to call, what to do, how to restore | A written plan, tested once a year |

**REMEMBER**

For small organisations, the highest-value controls are usually **MFA, patching, tested backups and email security**. Get those right before buying anything advanced.

**QUICK CHECK (answers at the back)**

37. Name the four highest-value controls for a small organisation.
38. What does "least privilege" mean for everyday staff accounts?

# 16 Email and Microsoft 365 security

> **Email is the front door for most attacks on businesses: phishing, malware and business email compromise (BEC), where an attacker takes over or impersonates a mailbox to redirect payments.**

## Email authentication: SPF, DKIM, DMARC

| Record | What it proves | Example DNS TXT record |
|---|---|---|
| **SPF** | Which servers may send email for your domain | `v=spf1 include:spf.protection.outlook.com -all` |
| **DKIM** | The message was signed by your domain and not altered in transit | A public key published in DNS; the mail system signs each message |
| **DMARC** | What receivers should do when SPF/DKIM fail, and where to send reports | `v=DMARC1; p=quarantine; rua=mailto:dmarc@example.com` |

**Roll out DMARC gradually:** start with `p=none` to collect reports, fix legitimate senders, then move to `p=quarantine` and finally `p=reject`. Check any domain's records with `dig TXT example.com` and `dig TXT _dmarc.example.com`.

## Microsoft 365 / Entra ID baseline

- **MFA for everyone:** security defaults (free) or Conditional Access policies (Entra ID P1).
- **Block legacy authentication**, which bypasses MFA.
- **Separate admin accounts**, with as few Global Administrators as possible (but at least two, including a break-glass account).
- **Defender for Office 365** protections such as Safe Links and Safe Attachments, where licensed.
- **Disable automatic external forwarding**, a classic BEC trick for quietly copying mail out.
- **Turn on audit logging**, and watch for suspicious **inbox rules** (e.g. rules that move payment emails to a hidden folder).
- Control **app consent**, so users can't grant risky third-party apps access to mail and files.

**REMEMBER**

**BEC signs:** a sign-in from an unusual country, a new inbox rule, email forwarding to an outside address, and then a "change of bank details" message. Alerting on those catches many attacks early.

**QUICK CHECK (answers at the back)**

39. What do SPF, DKIM and DMARC each do?
40. Why roll DMARC out starting with p=none?
41. Name two signs of business email compromise.

# 17 Vulnerability management, patching and backups

> **Vulnerability management is a cycle: find weaknesses, decide which matter most, fix them, and prove they're fixed.**

## The cycle

1. **Discover:** keep an inventory and scan systems for known vulnerabilities (CVEs).
2. **Prioritise:** not by score alone. Combine the **CVSS** severity with whether it's **actively exploited** (CISA's Known Exploited Vulnerabilities list is a good signal), whether the system is exposed to the internet, and how important it is to the business.
3. **Remediate:** patch, upgrade, or apply a workaround (disable the feature, restrict network access).
4. **Verify:** rescan to confirm the fix.
5. **Report:** show the trend over time.

| Tool | Type | Notes |
|---|---|---|
| Wazuh vulnerability detection | Agent-based, free | Uses the software inventory your agents already collect |
| Wazuh SCA (configuration assessment) | Agent-based, free | Checks settings against CIS benchmarks |
| Greenbone / OpenVAS | Network scanner, open source | Scans hosts over the network |
| Defender Vulnerability Management | Commercial | Built into Defender for Endpoint and Defender for Servers |
| Amazon Inspector | Commercial (AWS) | Scans EC2, container images and Lambda |

**Only scan systems you own or have written permission to test.** For a client, that permission must be part of the agreement.

## Patching in practice

- Enable automatic updates for operating systems and browsers.
- Agree a cadence: critical and actively exploited fixes within days, others monthly.
- Test on a few machines first, then roll out.
- Track what can't be patched (old systems) and isolate it.

## Backups, revisited

Follow 3-2-1 with at least one immutable or offline copy (Guide 2, chapter 6). Back up Microsoft 365 or Google Workspace data too: SaaS providers keep the service running, but restoring *your* deleted or encrypted data is largely your responsibility (shared responsibility again). **Test a restore** on a schedule and record the result.

**QUICK CHECK (answers at the back)**

12. Why isn't the CVSS score alone enough to prioritise a fix?
13. What must you have before scanning a client's systems?

14. Why back up SaaS data such as Microsoft 365?

# 18 Running security monitoring as a service

> **Monitoring someone else's environment means turning alerts into clear, timely action, and showing the value in plain language.**

## The operating loop

1. **Onboard:** agree scope in writing; install agents; connect log sources (endpoints, Microsoft 365 / Entra ID, firewall); record a baseline.
2. **Tune:** spend the first weeks removing noise and duplicates (your lab already taught you this).
3. **Triage:** agree response times per severity, e.g. "critical: acknowledged within 1 hour".
4. **Escalate and respond:** follow written playbooks; contact the agreed person; record every action.
5. **Report:** a short monthly report.
6. **Improve:** new detections from each incident and near-miss.

## A monthly security report

| Section | Contents |
|---|---|
| Summary | Three sentences: overall status, the biggest risk, the top recommendation |
| Alerts and incidents | Counts by severity; anything investigated and what was found |
| Vulnerabilities | Open critical/high items, and the trend versus last month |
| Hygiene | MFA coverage, patch status, backup test result, devices without protection |
| Recommendations | Up to three actions, ranked, in plain language |

## An incident response plan on one page

Who declares an incident; who to call (names and phone numbers, including outside help); first steps for common cases (phishing click, ransomware, account takeover, lost laptop); where backups are and how to restore; who handles legal, regulator and customer communication; and when to review the plan.

## Professional responsibilities

- **A written agreement** covering scope, permissions, confidentiality (NDA), data handling and liability, before touching any system.
- **Handle client data carefully:** least access, encryption, and no client data in personal tools.
- **Know your limits:** have a plan for incidents beyond your capacity, such as an escalation partner.

QUICK CHECK (answers at the back)

15. What should be agreed in writing before monitoring a client?
16. List the five sections of a monthly security report.

# 19 Frameworks and compliance

> **Frameworks give a shared structure for security programmes; laws and standards set requirements organisations must meet. Knowing the main ones helps you speak the language of managers, auditors and clients.**

| Name | Type | In one line |
|---|---|---|
| **NIST Cybersecurity Framework 2.0** | Framework | Six functions: **Govern, Identify, Protect, Detect, Respond, Recover** |
| **CIS Critical Security Controls** | Prioritised controls | 18 controls; Implementation Group 1 is the essential baseline |
| **ISO/IEC 27001** | Certifiable standard | An information security management system (ISMS) with risk-based controls |
| **SOC 2** | Audit report | Common for service providers, especially selling to US clients |
| **PCI DSS** | Industry standard | Required for anyone storing, processing or transmitting payment card data |
| **GDPR** | Law (EU/UK) | Personal data protection, with breach notification duties |
| **NDPA** (Nigeria Data Protection Act 2023) | Law (Nigeria) | Personal data protection in Nigeria, overseen by the Nigeria Data Protection Commission (NDPC) |
| **MITRE ATT&CK** | Knowledge base | Attacker tactics and techniques, used to map detections (you already use it) |

## How they connect to your work

- Your Wazuh rules already show compliance mappings (PCI DSS, GDPR, NIST), because detection evidence supports audits.
- Cloud posture tools score you against benchmarks (CIS, the Microsoft cloud security benchmark, AWS best practices).
- Data protection laws usually require **appropriate security measures** and **timely breach notification**, which is why logging, IR plans and backups matter beyond technology.

**REMEMBER**

This guide explains frameworks for learning purposes. Legal requirements vary by country and change over time. For real compliance decisions, check the official text and get qualified legal advice.

**QUICK CHECK (answers at the back)**

17. Name the six functions of NIST CSF 2.0.
18. Which standard applies to organisations handling payment cards?
19. Which law governs personal data protection in Nigeria?

# 20 Glossary

| Term | Meaning |
|---|---|
| Availability zone | A separate data centre within a region |
| BEC | Business email compromise: mailbox takeover or impersonation, often to redirect payments |
| Break-glass account | An emergency admin account, kept separate and closely monitored |
| CloudTrail | AWS log of API activity in an account |
| Conditional Access | Entra ID rules that grant or block sign-ins based on risk and context |
| CSPM | Cloud security posture management: continuous misconfiguration scanning |
| CVE / CVSS | A known vulnerability's ID / its severity score |
| DMARC | Email policy telling receivers how to handle unauthenticated mail |
| Entra ID | Microsoft's cloud identity service (formerly Azure AD) |
| GuardDuty | AWS threat detection service |
| IaC | Infrastructure as Code: defining infrastructure in files (e.g. Terraform) |
| KQL | Kusto Query Language, used in Sentinel and Log Analytics |
| Landing zone | A secure, pre-configured cloud foundation |
| Managed identity | An Azure identity for a resource, with no secrets to manage |
| NSG | Network security group: Azure's stateful network filter |
| PIM | Privileged Identity Management: just-in-time admin access |
| Private endpoint | A private IP inside your VNet for a PaaS service |
| RBAC | Role-based access control |
| SAS / pre-signed URL | A time-limited link granting access to storage |
| Sentinel | Microsoft's cloud SIEM and SOAR |
| Shared responsibility | The split of security duties between provider and customer |
| SOAR | Security orchestration, automation and response |
| VNet / VPC | A private network in Azure / AWS |

# Answers to the quick checks

1. On-demand self-service, broad network access, resource pooling, rapid elasticity, measured service.
2. Resource pooling.
3. You, the customer.
4. Azure: App Service or Azure SQL. AWS: Elastic Beanstalk or RDS.
5. Your data, your users and accounts, and access and configuration settings.
6. Private and public environments connected and used together.
7. Control over sensitive data, regulation, or predictable costs at large scale.
8. The provider.
9. Any two of: data, identities and accounts, access permissions, configuration.
10. An AWS account.
11. MFA on the top-level account, and a budget with alerts.
12. It has no stored secret that can leak; credentials are short-lived and managed for you.
13. Azure Bastion or AWS Session Manager.
14. A blob container inside a storage account.
15. Anyone who gets the link has access until it expires. Long-lived links act like leaked passwords.
16. Any two of: versioning, soft delete, immutable storage / Object Lock, backups.
17. The security group (network ACLs are stateless).
18. To reach a PaaS service through a private IP in your VNet, without using the public internet.
19. Shared security services are managed once, centrally, and every spoke's traffic can be controlled there.
20. Amazon SQS.
21. Any three of: no public access (private endpoints), identity-based authentication, encryption at rest and in transit, backups, auditing / threat detection, least-privilege database users.
22. A security principal, a role definition and a scope.
23. It's implicitly denied.
24. No long-lived secret to leak or rotate; Azure handles the credentials.
25. At rest (encryption, e.g. Key Vault / KMS keys); in transit (TLS / HTTPS-only); in use (confidential computing).
26. An encryption key you control in Key Vault or KMS. It lets you control rotation and revoke access, which some compliance rules require.
27. Azure Key Vault or AWS Secrets Manager.
28. Continuously scans cloud resources for misconfigurations and scores your security posture.
29. Any four of: public storage, SSH/RDP open to the internet, no MFA on admins, keys in code, over-permissive roles, public databases, logging off, public snapshots.
30. Any two of: it can be reviewed and scanned before deployment, it records changes in Git, it rebuilds environments identically, it destroys labs cleanly.
31. Azure: the Activity Log. AWS: CloudTrail.
32. CloudTrail events, VPC Flow Logs and DNS logs.
33. So an attacker who compromises a workload can't delete the evidence.
34. Preparation; detection and analysis; containment, eradication and recovery; post-incident activity.
35. Deactivate the key immediately (then investigate what it was used for).
36. To preserve evidence. Deleting the VM destroys its disk and the forensic trail.
37. MFA, patching, tested backups and email security.
38. Staff use standard accounts day to day, with admin rights only in separate accounts used when needed.
39. SPF lists allowed senders; DKIM signs messages; DMARC sets the policy for failures and collects reports.
40. To see all legitimate senders first, so real email isn't blocked when the policy is tightened.

41. Any two of: an unusual sign-in location, a new inbox rule, external forwarding, a sudden "change of bank details".
42. Severity doesn't show whether it's being exploited, whether the system is exposed, or how important the system is.
43. Written permission (part of the signed agreement).
44. Restoring your deleted or encrypted data is largely your responsibility, not the provider's.
45. Scope, permissions, confidentiality (NDA), data handling and liability.
46. Summary; alerts and incidents; vulnerabilities; hygiene; recommendations.
47. Govern, Identify, Protect, Detect, Respond, Recover.
48. PCI DSS.
49. The Nigeria Data Protection Act (NDPA) 2023, overseen by the NDPC.